

## **Introducción**

En marzo de 2025, se reportó que una máquina Debian estaba siendo atacada. Por lo cual, se procedió a realizar un análisis forense para revisar qué estaba ocurriendo y así encontrar la causa, analizarla y mitigarla para que la máquina volviera a ser segura.

## **Análisis Forense**

Se realizó un ping desde una máquina Kali a la máquina comprometida para detectar si daba respuesta, lo cual fue satisfactorio. Se usó la herramienta Nmap con los siguientes parámetros: `-sS -sV -O -p 192.168.1.48` para detectar puertos y servicios en ejecución. Se encontraron puertos abiertos como 21, 22 y 80, así como un servidor Apache 2.4.62 activo. Estos son puertos importantes, ya que, si no se configuran correctamente, se puede acceder a través de ellos a información sensible.

Lo siguiente fue ingresar desde otra máquina a la máquina comprometida por medio de conexión SSH. Este ingreso fue satisfactorio, utilizando el siguiente comando: `ssh debian@192.168.1.48`. A través de este ingreso, se continuó analizando la configuración de `apache2.conf`. Cabe destacar que, antes de analizar la configuración, se ingresó a internet (Firefox) desde la máquina comprometida y se abrió una página para restaurar sesión. Se le dio a restaurar sesión y se abrió WordPress (que gestiona páginas web). No debería haberse abierto WordPress sin tener que introducir el nombre de usuario y contraseña.

En el directorio `/etc/apache2/apache2.conf`, se usó la herramienta `grep` para buscar patrones específicos y se encontró que los directorios web estaban listables, es decir, se podía tener acceso a archivos importantes debido a esta debilidad.

También se usó la herramienta `grep` para revisar los logs de Apache, pero no hubo registros que indicaran alguna actividad sospechosa. Se buscaron y analizaron los logs del sistema, como `error.log` y `access.log`, pero no estaban en el directorio habitual. Se analizaron los accesos SSH con `journalctl -u ssh` y se encontró un acceso satisfactorio con una IP desconocida.

Lo siguiente que se realizó fue dirigirse al directorio raíz de WordPress `/var/www/html/wordpress`. Se detectó que en este directorio, donde se encuentra información o acceso a información importante, se tenían permisos excesivos.

Se ejecutó `ps aux` para analizar si había procesos en ejecución inusuales o que estuvieran ejecutándose con recursos más de lo usual (lo cual no arrojó nada inusual).

Se ingresó a la base de datos con MariaDB ejecutando `sudo mysql -u root -p`. Estando allí, se detectó un usuario poco común, por lo cual se revisaron los privilegios de los usuarios y se encontraron configuraciones incorrectas con permisos excesivos.

Se instaló y ejecutó chkrootkit y rkhunter respectivamente para buscar rootkits y malware. rkhunter generó una advertencia que indicaba que el acceso a la cuenta root a través de SSH estaba permitido, y se verificó que esta configuración estaba presente.

Por último, se realizó un escaneo de vulnerabilidades profundo con Nmap, que detectó varios aspectos que ya se habían identificado, como las vulnerabilidades y sus exploits del puerto 21, y que se permitía acceso anónimo a través de este puerto. Sobre el puerto 22, arrojó una gran cantidad de vulnerabilidades y sus exploits. También arrojó que se debían realizar revisiones a unos archivos referentes al puerto 80.

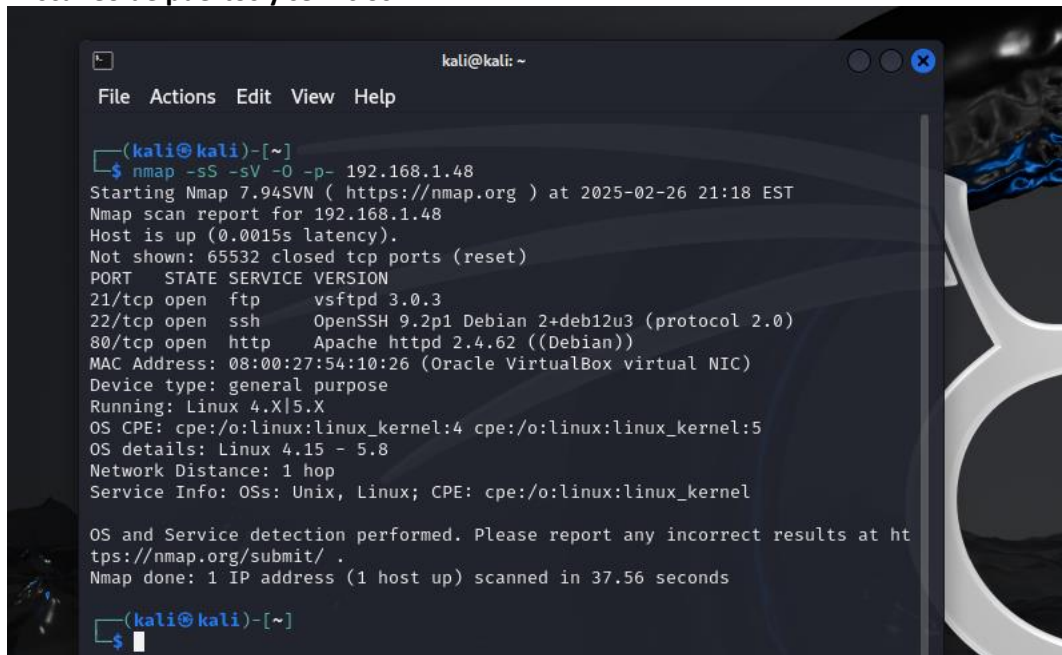
### Vulnerabilidades Mitigadas

- Se instaló un firewall y se configuró de acuerdo a las necesidades.
- Se configuró el directorio raíz de WordPress para que fuera seguro, aplicando la configuración con permisos de menor privilegio.
- Se configuró FTP para que no tuviera activo el acceso anónimo y también se cerró ese puerto, ya que no era necesario.
- Se deshabilitó en apache2.conf la opción de listar directorios web.
- Se mejoró y se hizo más robusta la configuración de los usuarios de la base de datos, y se configuraron los permisos necesarios para los usuarios.
- Se deshabilitó el acceso a root por SSH y se actualizó el sistema para aplicar parches de seguridad.

### Evidencias

#### Análisis forense:

##### - Escaneo de puertos y servicios

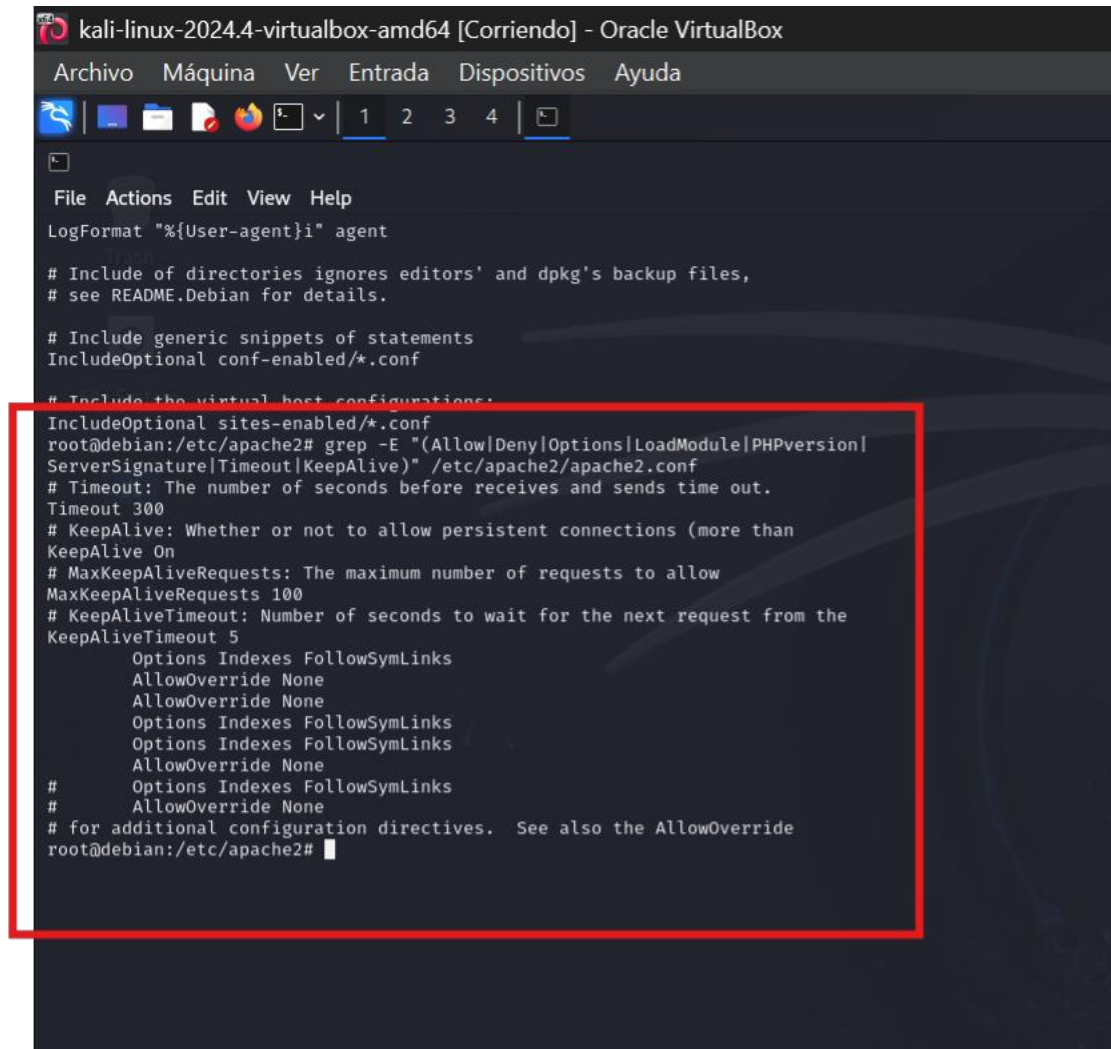


```
(kali@kali)-[~]
$ nmap -sS -sV -O -p- 192.168.1.48
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-26 21:18 EST
Nmap scan report for 192.168.1.48
Host is up (0.0015s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
MAC Address: 08:00:27:54:10:26 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.56 seconds

(kali@kali)-[~]
$
```

## - Directorio web listable



```
kali-linux-2024.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

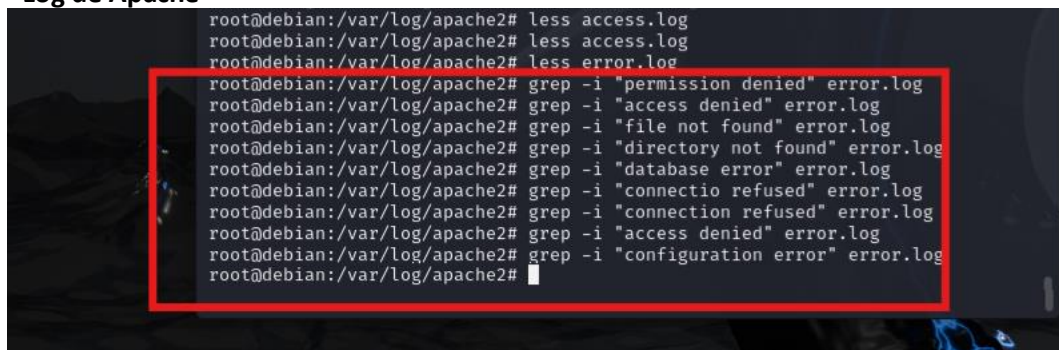
File  Actions  Edit  View  Help
LogFormat "%{User-agent}i" agent

# Include of directories ignores editors' and dpkg's backup files,
# see README.Debian for details.

# Include generic snippets of statements
IncludeOptional conf-enabled/*.conf

# Include the virtual host configurations:
IncludeOptional sites-enabled/*.conf
root@debian:/etc/apache2# grep -E "(Allow|Deny|Options|LoadModule|PHPVersion|
ServerSignature|Timeout|KeepAlive)" /etc/apache2/apache2.conf
# Timeout: The number of seconds before receives and sends time out.
Timeout 300
# KeepAlive: Whether or not to allow persistent connections (more than
KeepAlive On
# MaxKeepAliveRequests: The maximum number of requests to allow
MaxKeepAliveRequests 100
# KeepAliveTimeout: Number of seconds to wait for the next request from the
KeepAliveTimeout 5
    Options Indexes FollowSymLinks
    AllowOverride None
    AllowOverride None
    Options Indexes FollowSymLinks
    Options Indexes FollowSymLinks
    AllowOverride None
#    Options Indexes FollowSymLinks
#    AllowOverride None
# for additional configuration directives. See also the AllowOverride
root@debian:/etc/apache2#
```

## - Log de Apache



```
root@debian:/var/log/apache2# less access.log
root@debian:/var/log/apache2# less access.log
root@debian:/var/log/apache2# less error.log
root@debian:/var/log/apache2# grep -i "permission denied" error.log
root@debian:/var/log/apache2# grep -i "access denied" error.log
root@debian:/var/log/apache2# grep -i "file not found" error.log
root@debian:/var/log/apache2# grep -i "directory not found" error.log
root@debian:/var/log/apache2# grep -i "database error" error.log
root@debian:/var/log/apache2# grep -i "connectio refused" error.log
root@debian:/var/log/apache2# grep -i "connection refused" error.log
root@debian:/var/log/apache2# grep -i "access denied" error.log
root@debian:/var/log/apache2# grep -i "configuration error" error.log
root@debian:/var/log/apache2#
```

## Log SSH con journalctl

024.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox

quina Ver Entrada Dispositivos Ayuda

1 2 3 4

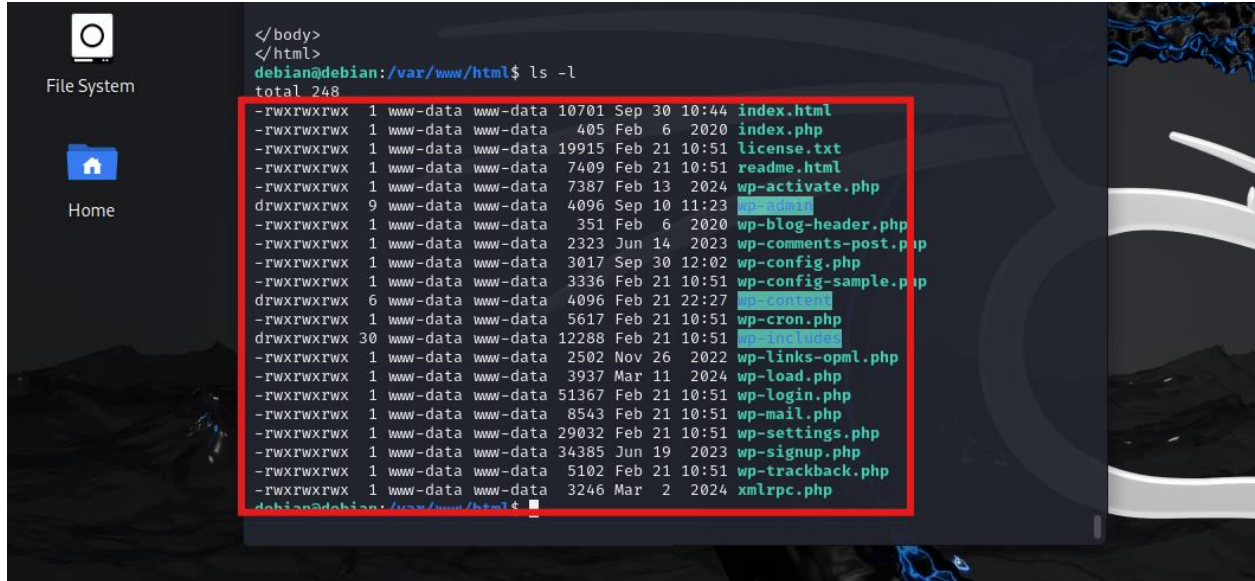
```
debian@debian: /var/log

File Actions Edit View Help

Oct 08 16:14:16 debian sshd[560]: Received signal 15; terminating.
Oct 08 16:14:16 debian systemd[1]: ssh.service: Deactivated successfully.
Oct 08 16:14:16 debian systemd[1]: Stopped ssh.service - OpenBSD Secure Shell server.
Oct 08 16:14:16 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:14:16 debian sshd[5341]: Server listening on 0.0.0.0 port 22.
Oct 08 16:14:16 debian sshd[5341]: Server listening on :: port 22.
Oct 08 16:14:16 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot 342683d8f35244b08c4f3863f2978eca --
Oct 08 16:43:18 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:43:18 debian sshd[543]: Server listening on 0.0.0.0 port 22.
Oct 08 16:43:18 debian sshd[543]: Server listening on :: port 22.
Oct 08 16:43:18 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot d28e179bf5884b25bf94452c79fd0afa --
Oct 08 16:48:02 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 16:48:02 debian sshd[555]: Server listening on 0.0.0.0 port 22.
Oct 08 16:48:02 debian sshd[555]: Server listening on :: port 22.
Oct 08 16:48:02 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
-- Boot af0a79f76920440c8e08594d6547449b --
Oct 08 17:28:37 debian systemd[1]: Starting ssh.service - OpenBSD Secure Shell server.
Oct 08 17:28:38 debian sshd[550]: Server listening on 0.0.0.0 port 22.
Oct 08 17:28:38 debian sshd[550]: Server listening on :: port 22.
Oct 08 17:28:38 debian systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 22.
Oct 08 17:40:59 debian sshd[1650]: pam_unix(sshd:session): session opened for user root
Oct 08 17:40:59 debian sshd[1650]: pam_env(sshd:session): deprecated reading of user e
-- Boot 7cc07c37204c4c649e1880a444c9bb9a --
lines 15-40
```

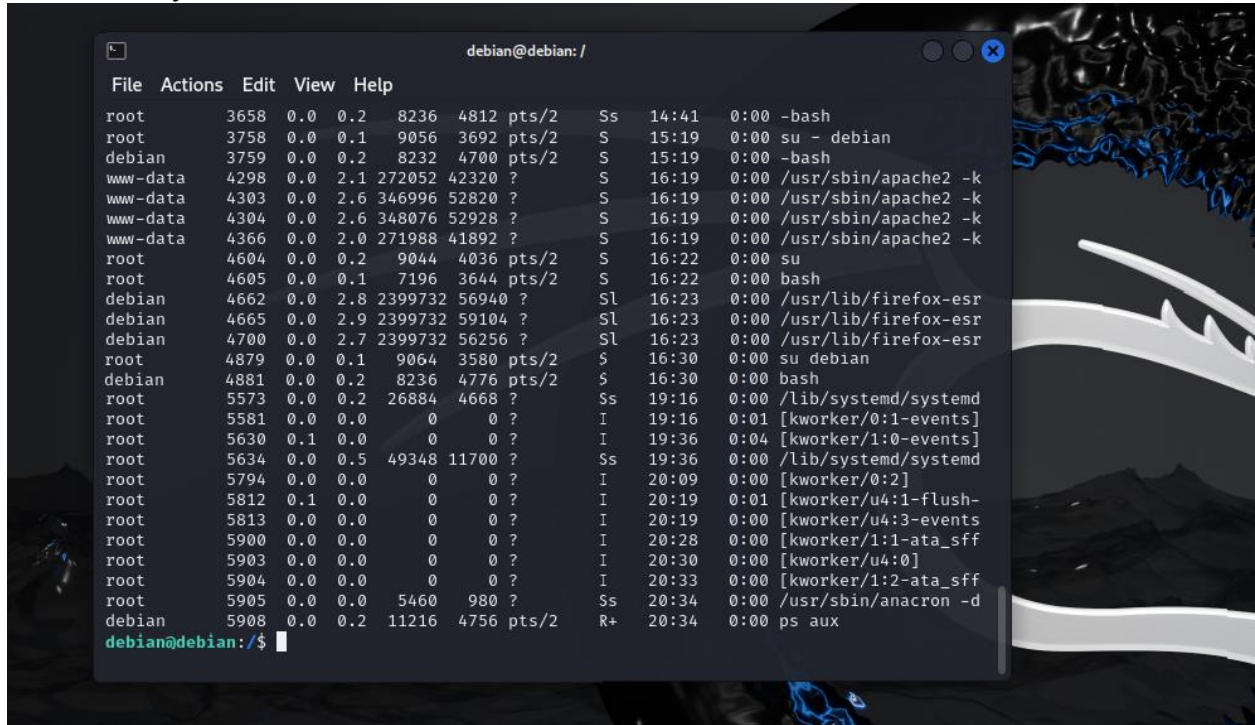


## Configuración de permisos en el directorio raíz de wordpress



```
</body>
</html>
debian@debian:/var/www/html$ ls -l
total 248
-rwxrwxrwx 1 www-data www-data 10701 Sep 30 10:44 index.html
-rwxrwxrwx 1 www-data www-data 405 Feb 6 2020 index.php
-rwxrwxrwx 1 www-data www-data 19915 Feb 21 10:51 license.txt
-rwxrwxrwx 1 www-data www-data 7409 Feb 21 10:51 readme.html
-rwxrwxrwx 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
drwxrwxrwx 9 www-data www-data 4096 Sep 10 11:23 wp-admin
-rwxrwxrwx 1 www-data www-data 351 Feb 6 2020 wp-blog-header.php
-rwxrwxrwx 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 12:02 wp-config.php
-rwxrwxrwx 1 www-data www-data 3336 Feb 21 10:51 wp-config-sample.php
drwxrwxrwx 6 www-data www-data 4096 Feb 21 22:27 wp-content
-rwxrwxrwx 1 www-data www-data 5617 Feb 21 10:51 wp-cron.php
drwxrwxrwx 30 www-data www-data 12288 Feb 21 10:51 wp-includes
-rwxrwxrwx 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rwxrwxrwx 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 www-data www-data 51367 Feb 21 10:51 wp-login.php
-rwxrwxrwx 1 www-data www-data 8543 Feb 21 10:51 wp-mail.php
-rwxrwxrwx 1 www-data www-data 29032 Feb 21 10:51 wp-settings.php
-rwxrwxrwx 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rwxrwxrwx 1 www-data www-data 5102 Feb 21 10:51 wp-trackback.php
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian: /var/www/html$
```

## Procesos en ejecución



```
File Actions Edit View Help
root      3658  0.0  0.2  8236  4812 pts/2    Ss   14:41   0:00 -bash
root      3758  0.0  0.1  9056  3692 pts/2    S    15:19   0:00 su - debian
debian    3759  0.0  0.2  8232  4700 pts/2    S    15:19   0:00 -bash
www-data  4298  0.0  2.1 272052 42320 ?        S    16:19   0:00 /usr/sbin/apache2 -k
www-data  4303  0.0  2.6 346996 52820 ?        S    16:19   0:00 /usr/sbin/apache2 -k
www-data  4304  0.0  2.6 348076 52928 ?        S    16:19   0:00 /usr/sbin/apache2 -k
www-data  4366  0.0  2.0 271988 41892 ?        S    16:19   0:00 /usr/sbin/apache2 -k
root      4604  0.0  0.2  9044  4036 pts/2    S    16:22   0:00 su
root      4605  0.0  0.1  7196  3644 pts/2    S    16:22   0:00 bash
debian    4662  0.0  2.8 2399732 56940 ?        Sl   16:23   0:00 /usr/lib/firefox-esr
debian    4665  0.0  2.9 2399732 59104 ?        Sl   16:23   0:00 /usr/lib/firefox-esr
debian    4700  0.0  2.7 2399732 56256 ?        Sl   16:23   0:00 /usr/lib/firefox-esr
root      4879  0.0  0.1  9064  3580 pts/2    S    16:30   0:00 su debian
debian    4881  0.0  0.2  8236  4776 pts/2    S    16:30   0:00 bash
root      5573  0.0  0.2 26884  4668 ?        Ss   19:16   0:00 /lib/systemd/systemd
root      5581  0.0  0.0  0  0 ?        I    19:16   0:01 [kworker/0:1-events]
root      5630  0.1  0.0  0  0 ?        I    19:36   0:04 [kworker/1:0-events]
root      5634  0.0  0.5 49348 11700 ?        Ss   19:36   0:00 /lib/systemd/systemd
root      5794  0.0  0.0  0  0 ?        I    20:09   0:00 [kworker/0:2]
root      5812  0.1  0.0  0  0 ?        I    20:19   0:01 [kworker/u4:1-flush-
root      5813  0.0  0.0  0  0 ?        I    20:19   0:00 [kworker/u4:3-events]
root      5900  0.0  0.0  0  0 ?        I    20:28   0:00 [kworker/1:1-ata_sff
root      5903  0.0  0.0  0  0 ?        I    20:30   0:00 [kworker/u4:0]
root      5904  0.0  0.0  0  0 ?        I    20:33   0:00 [kworker/1:2-ata_sff
root      5905  0.0  0.0  5460  980 ?        Ss   20:34   0:00 /usr/sbin/anacron -d
debian    5908  0.0  0.2 11216  4756 pts/2    R+   20:34   0:00 ps aux
debian@debian:/$
```

## Configuración en usuarios de base de datos

```
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian:/var/www/html$ sudo mysql -u root -p
[sudo] password for debian:
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 143
Server version: 10.11.6-MariaDB-0+deb12u1 Debian 12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SELECT User FROM mysql.user;
+-----+
| User          |
+-----+
| mariadb.sys   |
| mysql         |
| root          |
| user          |
| wordpressuser |
+-----+
5 rows in set (0.045 sec)

MariaDB [(none)]>
```

```
2 rows in set (0.001 sec)

MariaDB [(none)]> SHOW GRANTS FOR 'root'@'localhost';
+-----+
| Grants for root@localhost |
+-----+
| GRANT ALL PRIVILEGES ON *.* TO 'root'@'localhost' IDENTIFIED VIA mysql_native_password USING '*6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9' OR unix_socket WITH GRANT OPTION |
| GRANT PROXY ON '%' TO 'root'@'localhost' WITH GRANT OPTION |
+-----+
```

```
MariaDB [(none)]> SHOW GRANTS FOR 'wordpressuser'@'localhost';
+-----+
| Grants for wordpressuser@localhost |
+-----+
| GRANT USAGE ON *.* TO `wordpressuser`@`localhost` IDENTIFIED BY PASSWORD '*6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9' |
| GRANT ALL PRIVILEGES ON `wordpress`.* TO `wordpressuser`@`localhost` |
+-----+
2 rows in set (0.000 sec)

MariaDB [(none)]>
```

```
debian@debian: /var/www/html
File Actions Edit View Help

MariaDB [(none)]> SELECT User FROM mysql.user;
+-----+
| User          |
+-----+
| mariadb.sys   |
| mysql         |
| root          |
| user          |
| wordpressuser |
+-----+
5 rows in set (0.045 sec)

MariaDB [(none)]> SHOW GRANTS FOR 'user'@'localhost';
+-----+
| Grants for user@localhost |
+-----+
| GRANT ALL PRIVILEGES ON *.* TO `user`@`localhost` IDENTIFIED BY PASSWORD '*2470C0C06D  
EE42FD1618BB99005ADCA2EC9D1E19' WITH GRANT OPTION |
+-----+
1 row in set (0.010 sec)

MariaDB [(none)]> █
```

## Advertencia de Rkhunter

```
debian@debian: /
File Actions Edit View Help

Checking for system startup files          [ Found ]
Checking system startup files for malware  [ None found ]

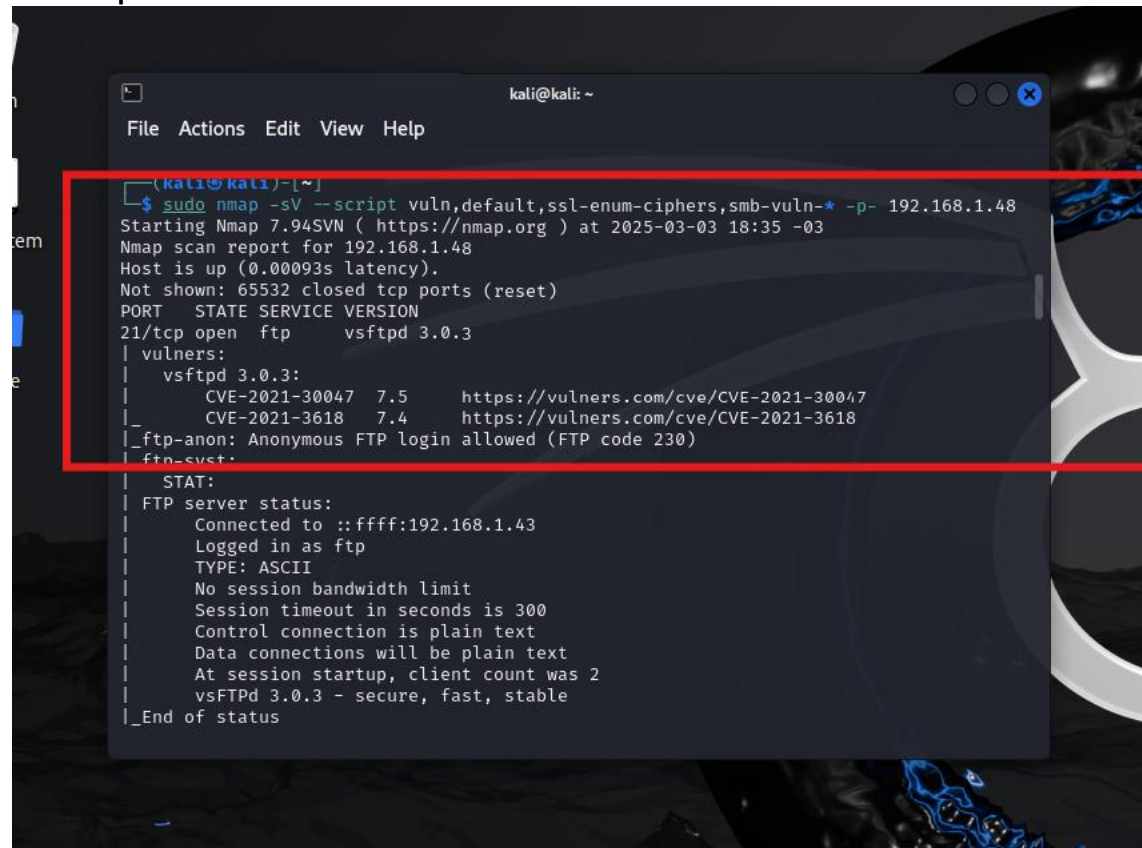
Performing group and account checks
Checking for passwd file                  [ Found ]
Checking for root equivalent (UID 0) accounts [ None found ]
Checking for passwordless accounts       [ None found ]
Checking for passwd file changes         [ None found ]
Checking for group file changes          [ None found ]
Checking root account shell history files [ OK ]

Performing system configuration file checks
Checking for an SSH configuration file    [ Found ]
Checking if SSH root access is allowed    [ Warning ]
Checking if SSH protocol v1 is allowed   [ Not set ]
Checking for other suspicious configuration settings [ None found ]
Checking for a running system logging daemon [ Found ]
Checking for a system logging configuration file [ Found ]

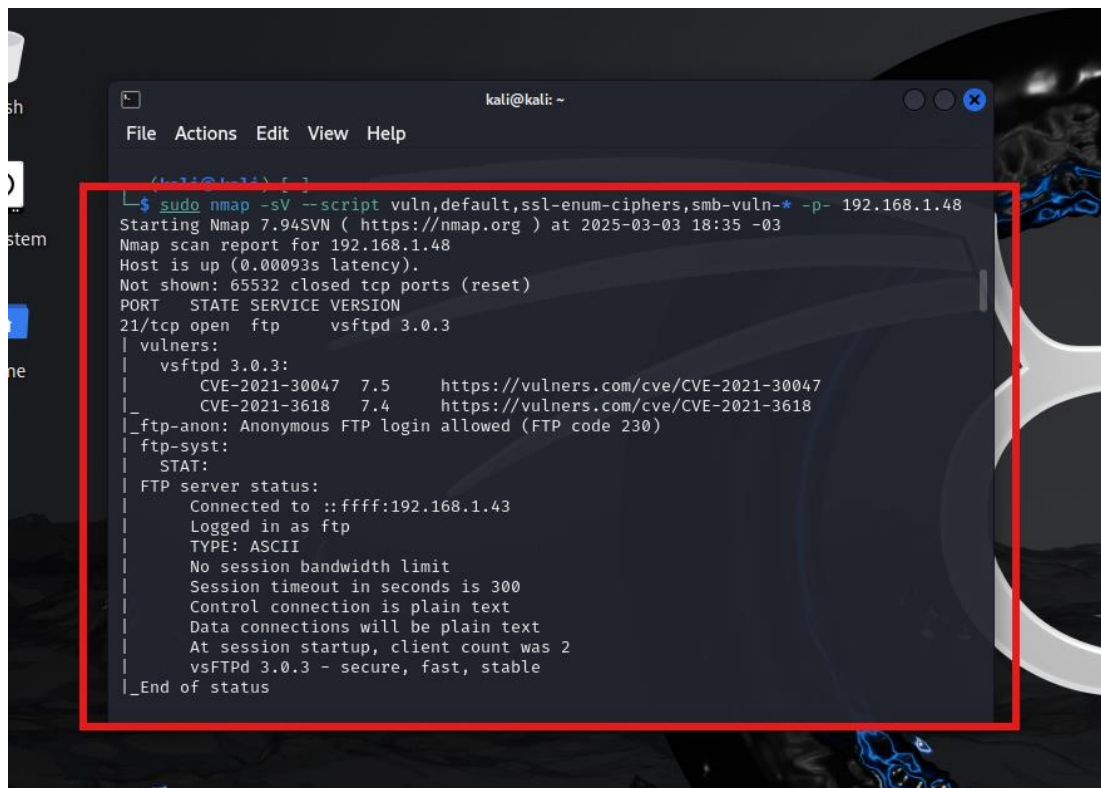
Performing filesystem checks
Checking /dev for suspicious file types   [ None found ]
Checking for hidden files and directories [ None found ]

[Press <ENTER> to continue]
```

## Escaneo profundo con NMAP

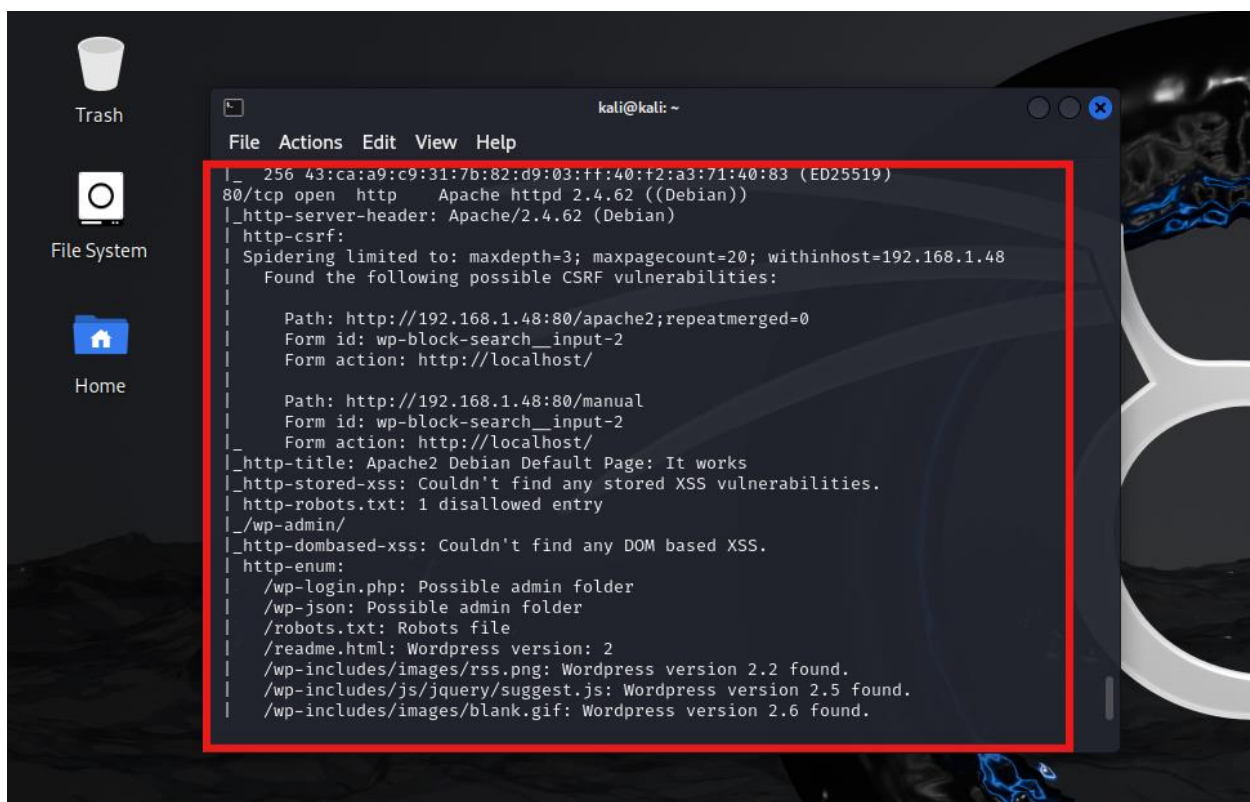
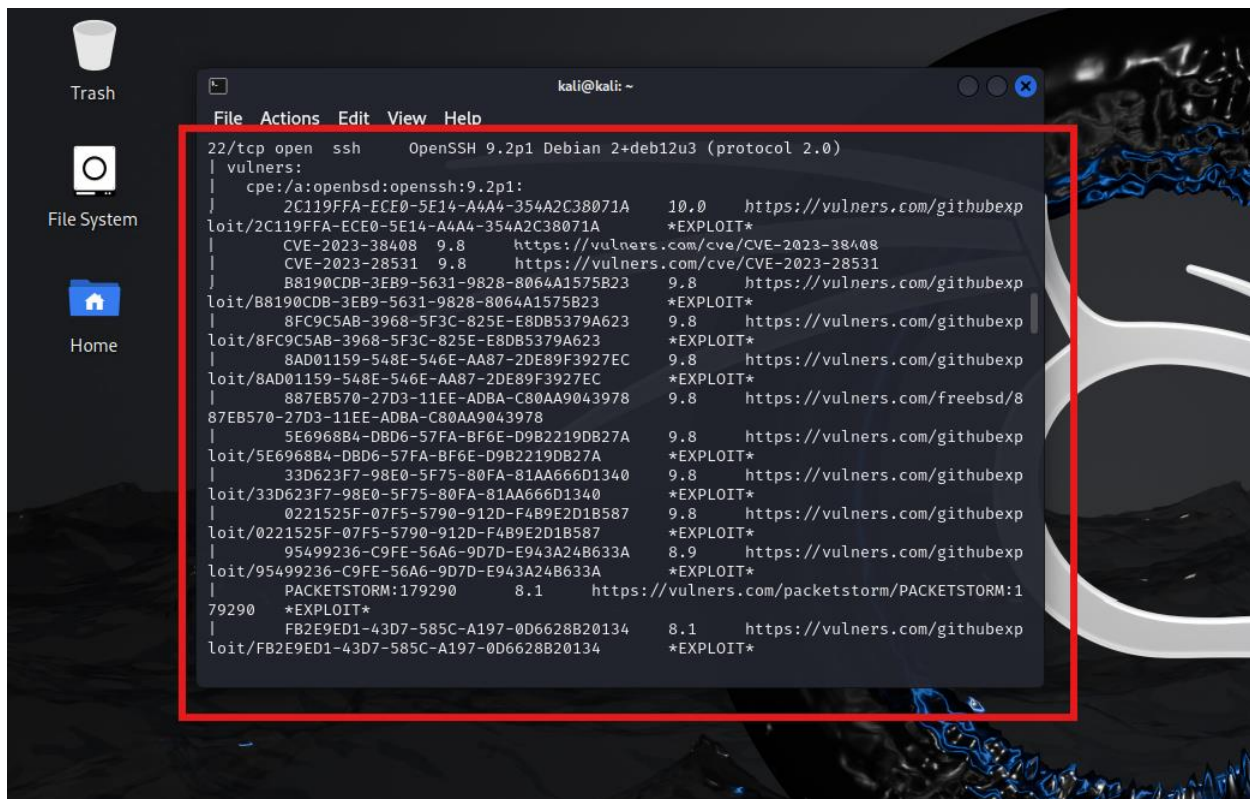


```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali) [~]  
$ sudo nmap -sV --script vuln,default,ssl-enum-ciphers,smb-vuln-* -p- 192.168.1.48  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-03 18:35 -03  
Nmap scan report for 192.168.1.48  
Host is up (0.00093s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
| vulners:  
|   vsftpd 3.0.3:  
|     CVE-2021-30047 7.5 https://vulners.com/cve/CVE-2021-30047  
|     CVE-2021-3618 7.4 https://vulners.com/cve/CVE-2021-3618  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_  Connected to ::ffff:192.168.1.43  
|_  Logged in as ftp  
|_  TYPE: ASCII  
|_  No session bandwidth limit  
|_  Session timeout in seconds is 300  
|_  Control connection is plain text  
|_  Data connections will be plain text  
|_  At session startup, client count was 2  
|_  vsFTPD 3.0.3 - secure, fast, stable  
|_End of status
```



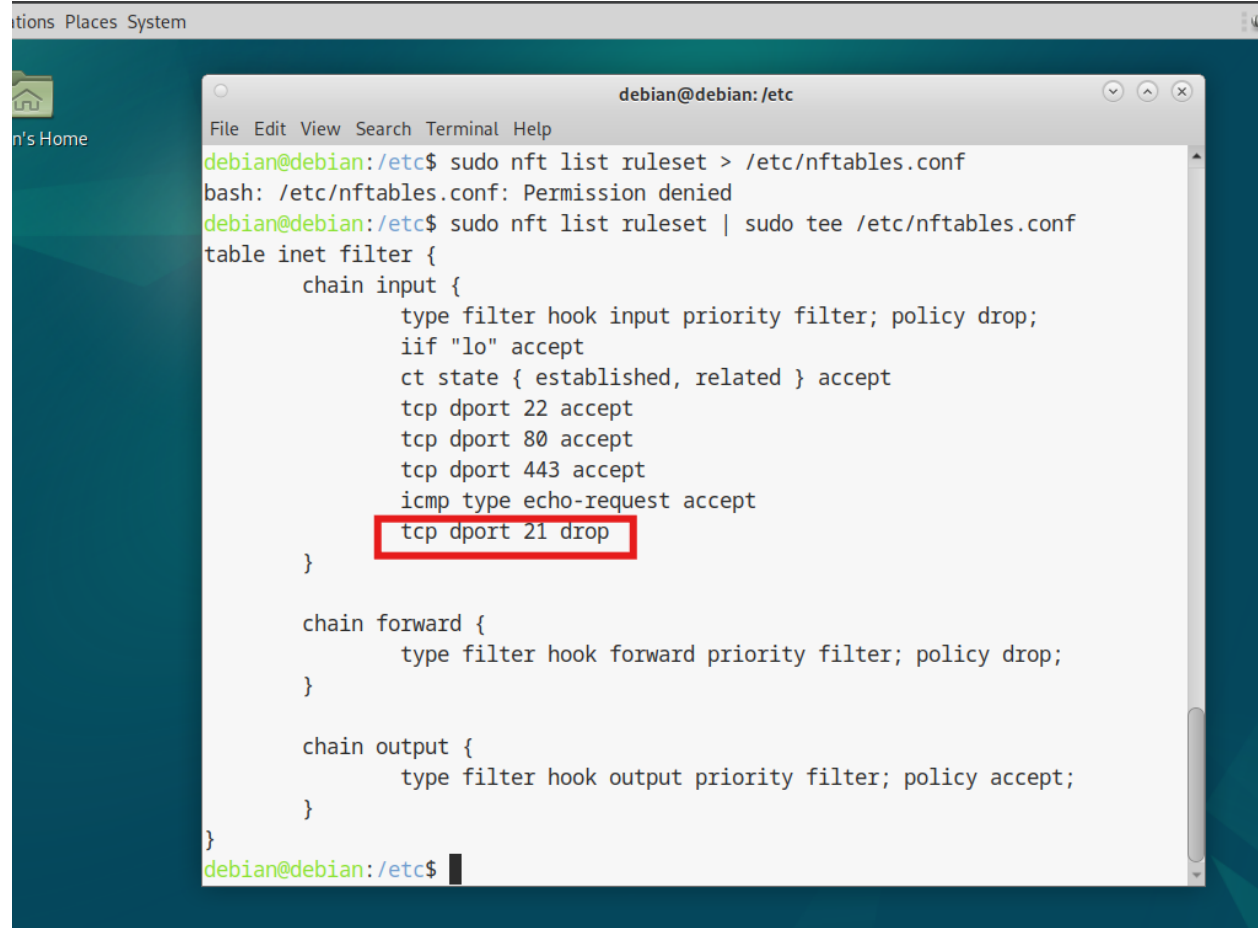
```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali) [~]  
$ sudo nmap -sV --script vuln,default,ssl-enum-ciphers,smb-vuln-* -p- 192.168.1.48  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-03 18:35 -03  
Nmap scan report for 192.168.1.48  
Host is up (0.00093s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
| vulners:  
|   vsftpd 3.0.3:  
|     CVE-2021-30047 7.5 https://vulners.com/cve/CVE-2021-30047  
|     CVE-2021-3618 7.4 https://vulners.com/cve/CVE-2021-3618  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_  Connected to ::ffff:192.168.1.43  
|_  Logged in as ftp  
|_  TYPE: ASCII  
|_  No session bandwidth limit  
|_  Session timeout in seconds is 300  
|_  Control connection is plain text  
|_  Data connections will be plain text  
|_  At session startup, client count was 2  
|_  vsFTPD 3.0.3 - secure, fast, stable  
|_End of status
```





## Vulnerabilidades mitigadas:

### - Configuración de un Firewall

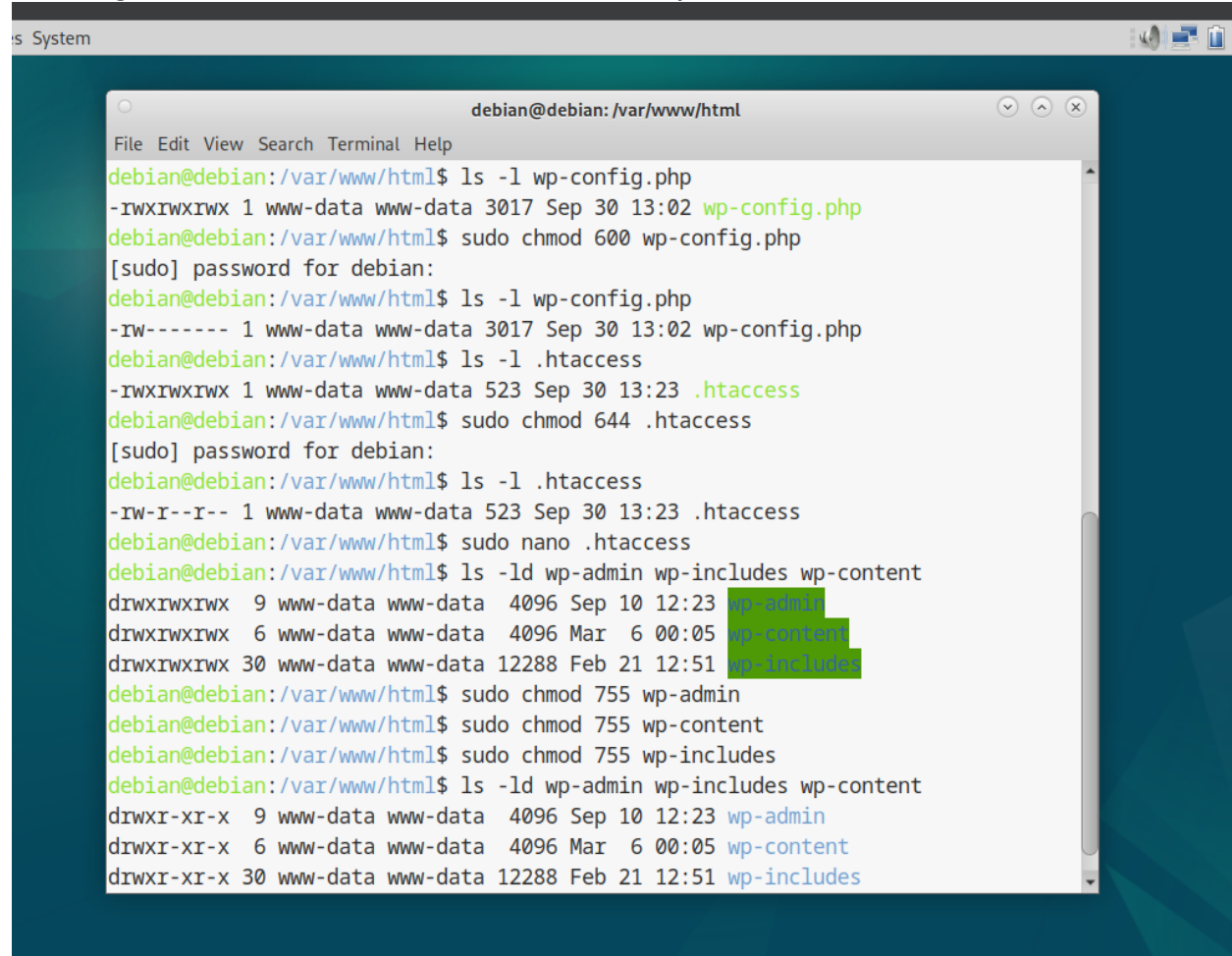


```
debian@debian:/etc$ sudo nft list ruleset > /etc/nftables.conf
bash: /etc/nftables.conf: Permission denied
debian@debian:/etc$ sudo nft list ruleset | sudo tee /etc/nftables.conf
table inet filter {
    chain input {
        type filter hook input priority filter; policy drop;
        iif "lo" accept
        ct state { established, related } accept
        tcp dport 22 accept
        tcp dport 80 accept
        tcp dport 443 accept
        icmp type echo-request accept
        tcp dport 21 drop
    }

    chain forward {
        type filter hook forward priority filter; policy drop;
    }

    chain output {
        type filter hook output priority filter; policy accept;
    }
}
debian@debian:/etc$
```

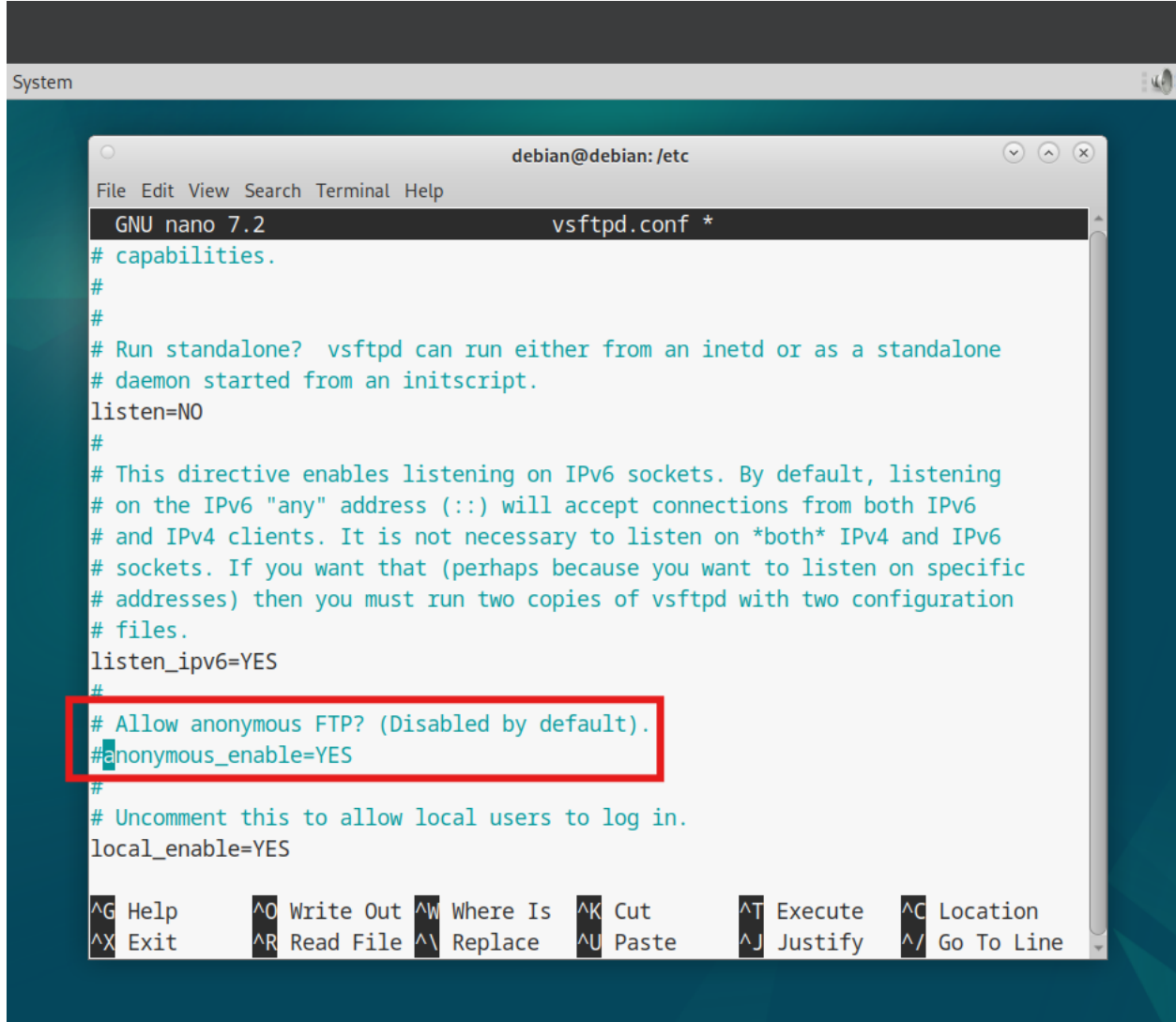
-Se configuró adecuadamente el directorio raíz de wordpress



A terminal window titled 'debian@debian: /var/www/html' showing the configuration of file permissions for WordPress. The user runs several commands to check and modify permissions for 'wp-config.php', '.htaccess', 'wp-admin', 'wp-content', and 'wp-includes'. The output shows the current permissions and the result of the 'chmod' commands. The files 'wp-admin', 'wp-content', and 'wp-includes' are highlighted in green in the original image.

```
File Edit View Search Terminal Help
debian@debian:/var/www/html$ ls -l wp-config.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 13:02 wp-config.php
debian@debian:/var/www/html$ sudo chmod 600 wp-config.php
[sudo] password for debian:
debian@debian:/var/www/html$ ls -l wp-config.php
-rw----- 1 www-data www-data 3017 Sep 30 13:02 wp-config.php
debian@debian:/var/www/html$ ls -l .htaccess
-rwxrwxrwx 1 www-data www-data 523 Sep 30 13:23 .htaccess
debian@debian:/var/www/html$ sudo chmod 644 .htaccess
[sudo] password for debian:
debian@debian:/var/www/html$ ls -l .htaccess
-rw-r--r-- 1 www-data www-data 523 Sep 30 13:23 .htaccess
debian@debian:/var/www/html$ sudo nano .htaccess
debian@debian:/var/www/html$ ls -ld wp-admin wp-includes wp-content
drwxrwxrwx 9 www-data www-data 4096 Sep 10 12:23 wp-admin
drwxrwxrwx 6 www-data www-data 4096 Mar 6 00:05 wp-content
drwxrwxrwx 30 www-data www-data 12288 Feb 21 12:51 wp-includes
debian@debian:/var/www/html$ sudo chmod 755 wp-admin
debian@debian:/var/www/html$ sudo chmod 755 wp-content
debian@debian:/var/www/html$ sudo chmod 755 wp-includes
debian@debian:/var/www/html$ ls -ld wp-admin wp-includes wp-content
drwxr-xr-x 9 www-data www-data 4096 Sep 10 12:23 wp-admin
drwxr-xr-x 6 www-data www-data 4096 Mar 6 00:05 wp-content
drwxr-xr-x 30 www-data www-data 12288 Feb 21 12:51 wp-includes
```

## - Configuración correcta de servicio FTP

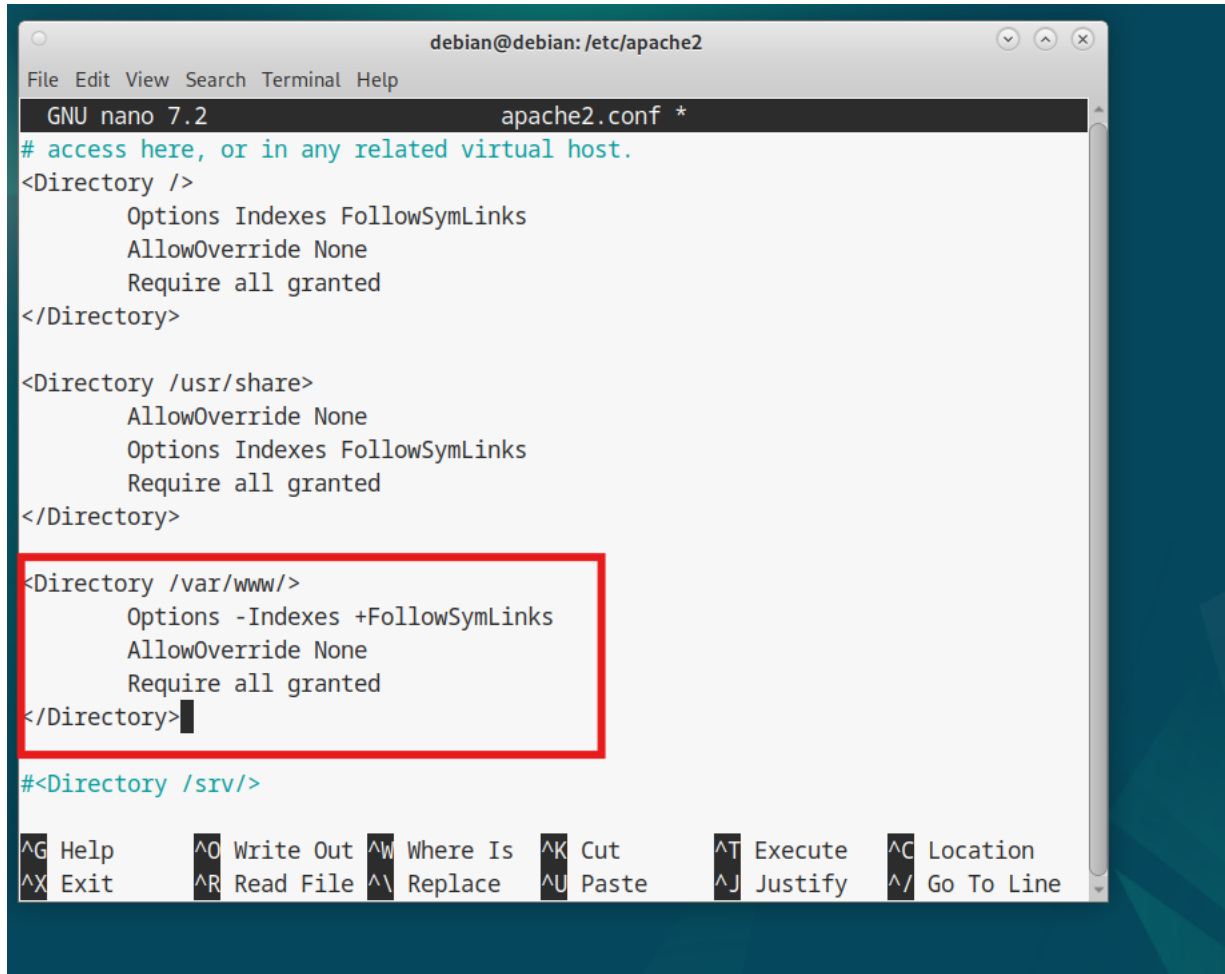


```
System
debian@debian: /etc
File Edit View Search Terminal Help
GNU nano 7.2 vsftpd.conf *
# capabilities.
#
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=YES
#
# Uncomment this to allow local users to log in.
local_enable=YES

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute  ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify  ^_ Go To Line
```



## -Se deshabilitó el directorio web listable



The screenshot shows a terminal window with the title 'debian@debian: /etc/apache2'. The window contains the GNU nano 7.2 editor editing the 'apache2.conf' file. The configuration for the /var/www directory is highlighted with a red box. The configuration sets 'Options -Indexes +FollowSymLinks', 'AllowOverride None', and 'Require all granted'. The cursor is at the end of the '</Directory>' tag for /var/www. Below the editor, a status bar shows various keyboard shortcuts like ^G Help, ^O Write Out, ^W Where Is, ^K Cut, ^T Execute, ^C Location, ^X Exit, ^R Read File, ^\ Replace, ^U Paste, ^J Justify, and ^\_ Go To Line.

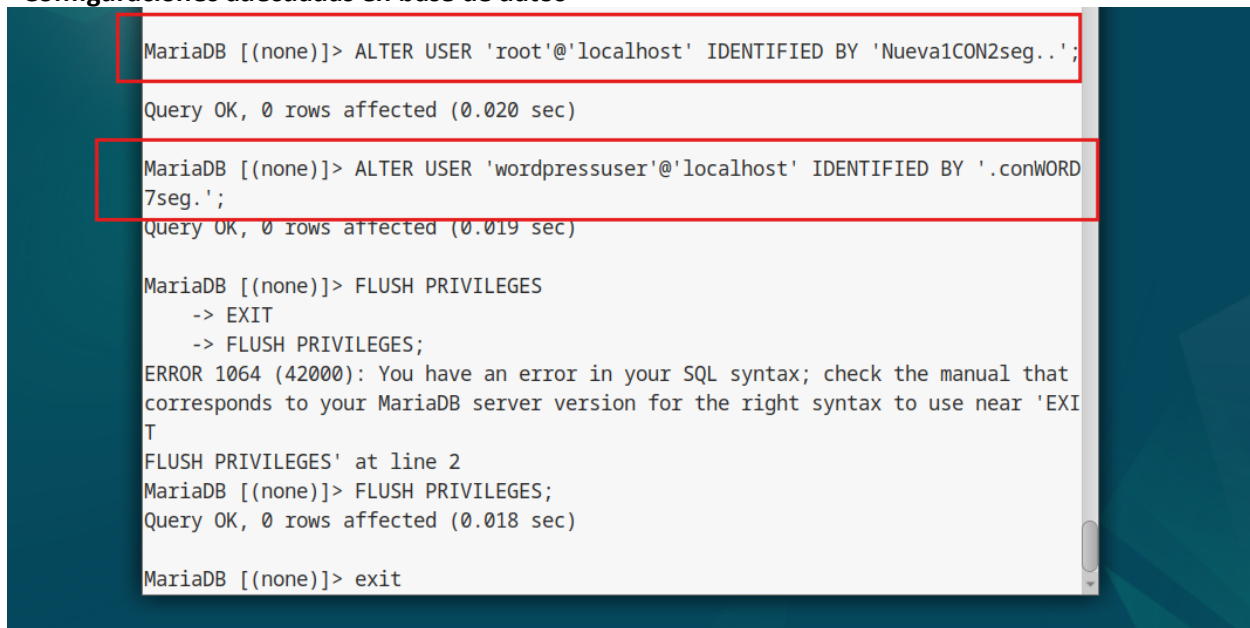
```
debian@debian: /etc/apache2
File Edit View Search Terminal Help
GNU nano 7.2 apache2.conf *
# access here, or in any related virtual host.
<Directory />
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

<Directory /usr/share>
    AllowOverride None
    Options Indexes FollowSymLinks
    Require all granted
</Directory>

<Directory /var/www/>
    Options -Indexes +FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
#<Directory /srv/>

^G Help    ^O Write Out  ^W Where Is  ^K Cut      ^T Execute   ^C Location
^X Exit    ^R Read File  ^\ Replace   ^U Paste    ^J Justify   ^_ Go To Line
```

## - Configuraciones adecuadas en base de datos



The screenshot shows a terminal window with the title 'MariaDB [(none)]>'. The window contains several SQL commands and their outputs. The first command is 'ALTER USER 'root'@'localhost' IDENTIFIED BY 'Nueva1CON2seg..';', which is highlighted with a red box. The output is 'Query OK, 0 rows affected (0.020 sec)'. The second command is 'ALTER USER 'wordpressuser'@'localhost' IDENTIFIED BY '.conWORD7seg.';', which is also highlighted with a red box. The output is 'Query OK, 0 rows affected (0.019 sec)'. The third command is 'FLUSH PRIVILEGES', which is followed by an error message: 'ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'EXIT' at line 2'. The fourth command is 'FLUSH PRIVILEGES;', which is followed by the output 'Query OK, 0 rows affected (0.018 sec)'. The final command is 'exit'.

```
MariaDB [(none)]> ALTER USER 'root'@'localhost' IDENTIFIED BY 'Nueva1CON2seg..';
Query OK, 0 rows affected (0.020 sec)

MariaDB [(none)]> ALTER USER 'wordpressuser'@'localhost' IDENTIFIED BY '.conWORD7seg.';
Query OK, 0 rows affected (0.019 sec)

MariaDB [(none)]> FLUSH PRIVILEGES
-> EXIT
-> FLUSH PRIVILEGES;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that
corresponds to your MariaDB server version for the right syntax to use near 'EXI
T
FLUSH PRIVILEGES' at line 2
MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.018 sec)

MariaDB [(none)]> exit
```

```

MariaDB [(none)]> USE wordpress
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [wordpress]> GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX,
ALTER, CREATE TEMPORARY TABLES, LOCK TABLES ON wordpress* TO 'wordpressuser'@'lo
calhost';
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that
corresponds to your MariaDB server version for the right syntax to use near '* T
O 'wordpressuser'@'localhost' at line 1
MariaDB [wordpress]> GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX,
ALTER, CREATE TEMPORARY TABLES, LOCK TABLES ON wordpress.* TO 'wordpressuser'@'l
ocalhost';
Query OK, 0 rows affected (0.022 sec)

MariaDB [wordpress]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.018 sec)

MariaDB [wordpress]>

```

## - Se deshabilitó acceso directo a root por SSH

```

debian@debian: /
File Edit View Search Terminal Help
GNU nano 7.2 /etc/ssh/sshd_config *
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
#PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute  ^C Location
^X Exit      ^R Read File ^N Replace   ^U Paste     ^J Justify  ^_ Go To Line

```

## **Conclusión**

El incidente de seguridad se originó no por una, sino por una gran cantidad de vulnerabilidades y configuraciones erróneas. Se verificó que no existen medidas de protección que detecten anomalías, así como la falta de sistemas actualizados. Estos sistemas, muchas veces, corrigen vulnerabilidades, y no tener estas actualizaciones vuelve más complejo restablecer la seguridad y, por ende, que la información confidencial no esté expuesta.

Todo es esencial en ciberseguridad, desde tener un firewall hasta un sistema de detección de intrusos. Cabe destacar que, si se corrompe y se divulga esa información, trae consigo problemas legales.

La ciberseguridad no es solo configuración de un día, exige programar actualizaciones y estar al día con las nuevas medidas y herramientas de seguridad.